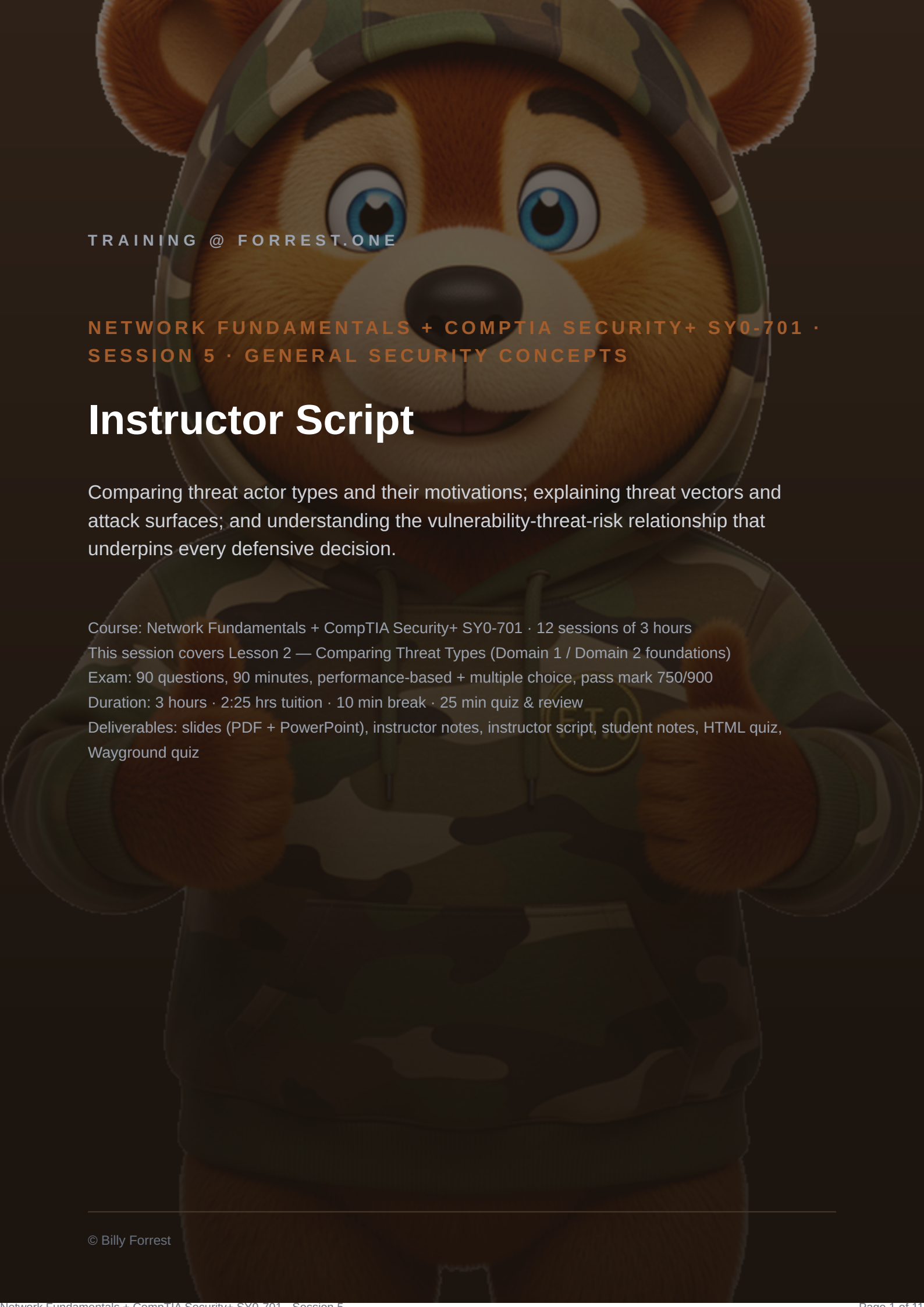




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 5 · GENERAL SECURITY CONCEPTS

Instructor Script

Comparing threat actor types and their motivations; explaining threat vectors and attack surfaces; and understanding the vulnerability-threat-risk relationship that underpins every defensive decision.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 2 — Comparing Threat Types (Domain 1 / Domain 2 foundations)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Script — Threats, Attack Types & Threat Actors

A word-for-word delivery script for Session 5. Stage directions appear in square brackets. Each slide runs roughly 45 to 90 seconds of speech; activities and discussions expand the timings in the instructor notes. Enrich any slide with the real-world examples from the session reference text, especially Stuxnet for a nation-state campaign, WannaCry for unpatched software and NotPetya for the supply chain.

Slide 1 · Title

Welcome to Session 5, Threats, Attack Types and Threat Actors. Session 4 built the foundations: the CIA triad, controls and frameworks. Today we study the adversary. Who attacks organisations, why they do it, and the paths they take. The exam frames most of this area as scenarios, so this session gives you the vocabulary to name the actor, the vector, the weakness and the control. You cannot defend against a threat you cannot name, so we begin by naming the actors.

Slide 2 · Where we are

Here is the shape of the session. Six chapters: know the adversary, the attack surface, vulnerabilities, malware and credential attacks, attacks on the network, and finally mitigation. Notice the direction of travel. We start with who is attacking, then where they can reach, then what they can abuse, then how they attack, and we finish on what stops them. Every technique in the middle of this session is paired with the control that answers it, so the session ends on defence rather than on fear.

Slide 3 · Session objectives

By the end of these three hours you will be able to define vulnerability, threat and risk; compare actors by resources, sophistication, motivation and intent; classify the actor types; map the attack surface and its vectors; explain the vulnerability types; describe the attacks, from malware to DNS; and apply the mitigations. Seven objectives, and the quiz tests every one.

Slide 4 · Vulnerability, threat and risk

Three terms, one relationship. A vulnerability is a weakness in a system or process. A threat is something that could exploit the weakness, whether a person, a tool or a method. Risk is the likelihood and impact of that exploitation happening. The formula: a threat that exploits a vulnerability creates risk. A weakness documented in a report is not risk; the moment someone is willing to exploit it, you have risk. Every actor we meet in this session supplies the capability, the motivation and the intent behind a risk.

Slide 5 · Attributes of threat actors

How do we compare threat actors? With four attributes. Resources are the money, technology and people an actor can commit, which set the scale of the attack. Sophistication is skill, from off the shelf tools up to custom exploits and unknown flaws. Motivation is the reason to act. Intent is the specific outcome sought, such as theft, disruption or espionage. Motivation sets the reason and intent sets the outcome, and together they predict the target. These attributes let you classify any actor you meet in a scenario.

Slide 6 · Motivations and intent

Why do they attack? Financial: ransomware, extortion, fraud, blackmail and card theft. Political or ideological: hacktivism, disinformation, protest and war. Strategic: espionage and data exfiltration. Personal: revenge, grievance, curiosity, and disruption for its own sake. And ethical: authorised testing, research and responsible disclosure, which is where the white hat sits. Motivation chooses the target; intent chooses the outcome. The financially motivated go where the money is, and the politically motivated go where the message lands.

Slide 7 · Nation-state actors and advanced persistent threats

Nation-state actors are the most capable adversaries you will face. Government sponsored, with deep funding, advanced technology and highly skilled staff, and often with legal protection at home. Their goals are strategic rather than financial: espionage, intellectual property theft, and disruption of critical infrastructure. Their signature is the Advanced Persistent Threat, the APT, a prolonged campaign that stays undetected. The early stages are reconnaissance, intrusion, foothold and privilege escalation; the late stages are internal reconnaissance, exfiltration and persistence. Stuxnet, Operation Aurora and NotPetya show the reach, and false flags show the determination to avoid attribution.

Slide 8 · Organised crime and the underground economy

Organised cybercrime runs like a legitimate business, with structured hierarchies, specialist roles and profit as the only goal. Their staples are ransomware, banking trojans that capture financial credentials, card theft, and business email compromise, where an executive is impersonated to authorise a payment. The underground economy sells stolen data and hacking tools on dark web marketplaces, paid for in cryptocurrency. Crime as a service rents out botnets, ransomware and denial of service, so a criminal needs no skill of their own. Crime keeps lowering its own barrier to entry.

Slide 9 · Hacktivists, unskilled attackers and insiders

Three more actor types, plus one that is easy to forget. Hacktivists are driven by an ideology or a political cause, and their tools are defacement, data leaks and denial of service. Unskilled attackers, often called script kiddies, lack the skill to build their own tools, so they run ready-made exploits against easy targets. The malicious insider steals or sabotages with legitimate access. The negligent insider simply makes a mistake, and that is the more common case. Shadow IT, the unauthorised tools staff adopt, places data outside

approved controls, so it is an actor type on the exam. Insiders are hardest to detect because their access is legitimate.

Slide 10 · Competitors and false flags

Two final points on actors. Competitors conduct cyber espionage to steal intellectual property and trade secrets, and they may run disinformation to damage reputation as well as to gain an advantage. And sophisticated actors work hard on deniability: false-flag operations deliberately mislead attribution towards somebody else. Attribution is hard by design, which is exactly why we analyse behaviour and intent rather than the label an attacker chooses.

Slide 11 · Discussion

[Run the discussion per the instructor notes.] Which threat actor type worries your organisation most, and why? [Walk each type and collect answers.] The insider has authorised access; organised crime brings ransomware; the nation-state brings espionage; the hacktivist brings disruption; the unskilled attacker takes whatever you left unpatched. The answer depends on what your organisation holds, and that is exactly how attribution should drive defence.

Slide 12 · Activity: match the actor

[Run the activity per the instructor notes. 8 minutes pairs, 4 minutes debrief.] A group defaces a government website to protest a policy: hacktivists, political motivation. An employee steals customer data to sell: malicious insider, financial. A state-sponsored team quietly exfiltrates defence research over a year: APT, strategic. An employee clicks a phishing link and causes a breach: negligent insider, not malicious. Type, motivation and surface together, always more than one label, because the exam will ask for the pair.

Slide 13 · The attack surface

Now the ground they attack on. The attack surface is every point where an unauthorised user could enter or extract data. It includes all the hardware, software, networks, processes and people an attacker can reach. And it grows with every technology you adopt. Cloud services put data within reach of the internet. Mobile devices carry sensitive data on hardware you do not fully control. Internet of Things devices often ship with weak security. Remote work pulls home networks inside your perimeter. Larger surface, more opportunities.

Slide 14 · Common threat vectors

Threat vectors are the paths an attacker uses to reach that surface. Phishing email is the most common: a deceptive message that persuades somebody to click, reply or pay. Malware arrives as an attachment, from a compromised website, or on infected removable media. A software vulnerability is a flaw left unpatched in software you already run. Social engineering manipulates a person into granting access. And wireless and cloud provide paths such as open networks, rogue access points and exposed services. The surface is every door into your environment, and a vector is how the attacker walks through one.

Slide 15 · The phishing family

Phishing is a family, and you must name the right member in a scenario. Phishing is bulk email to a wide audience, hoping that somebody clicks. Spear phishing is aimed at a named individual, using researched detail so the message reads as genuine. Whaling is spear phishing aimed at executives and key decision makers, and it often references real business matters. Smishing delivers the same deception by text message. And vishing is voice phishing over the telephone, pressing urgency or fear until the target complies. The target defines the type.

Slide 16 · Social engineering techniques

Beyond messages, social engineering attacks the person directly. Pretexting invents a scenario, with the attacker posing as a colleague, a supplier or support staff to extract information. Baiting offers something tempting, such as a universal serial bus, or USB, drive left where somebody will pick it up. Tailgating, also called piggybacking, is following an authorised person through a secure door. Shoulder surfing is watching a password being typed, and dumpster diving is reading what you discarded. The defence is awareness training, phishing simulation and easy reporting.

Slide 17 · Network and file-based vectors

Some vectors arrive through the network or inside a file. An unsecured wireless network lets an attacker intercept traffic, so weak or absent encryption is an invitation. A rogue access point is an unauthorised wireless device that users willingly join, believing it belongs to the organisation. A malicious document carries a hidden script or macro that runs when the file is opened, and an infected executable installs malware or leaves a backdoor. Removable media carries malware straight past network defences. Encryption and endpoint protection are the answers.

Slide 18 · Direct access, remote access and open services

Three more vector families. Direct access means USB ports, console access and wired connections, which is why physical control matters. Remote access means VPN, RDP, SSH and the remote administration tools, which is why exposed remote services draw constant attack. Open service ports are unnecessary TCP and UDP services left listening for anybody. Default credentials are unchanged factory passwords, and those are public knowledge. A watering hole compromises a site your target trusts, then delivers malware from it. Every one of these is a door, and doors are closed by configuration rather than by hope.

Slide 19 · Break

Ten minutes. When we return, the session turns from where an attacker can go to what they can abuse once they are there.

Slide 20 · Supply chain and software vulnerabilities

An attack needs a vector and a vulnerability, so here is where the weaknesses live. A supply chain attack reaches you through a supplier you trust, and the classic method is the software update, where malicious code inserted once reaches every customer. NotPetya spread exactly that way, through a compromised accounting package in Ukraine. Vendor credentials matter too, because a small supplier with weak security becomes the door into a much larger target. Software adds flaws of its own: unpatched systems, misconfiguration such as exposed storage, and zero-day vulnerabilities with no patch available at all.

Slide 21 · Application and web vulnerabilities

Application and web vulnerabilities are the classic programming flaws. Memory injection inserts code into a running program and redirects its execution, usually because input was never validated. A buffer overflow writes more data than a buffer holds and overwrites adjacent memory. A race condition depends on timing, letting an attacker reach a resource out of turn. Structured Query Language, or sequel, injection rewrites a database query. Cross-site scripting runs a script in another user's browser, cross-site request forgery makes a logged-in user submit an unwanted request, and session hijacking steals a session cookie. The injection succeeds only when code and data are mixed.

Slide 22 · Operating system and hardware vulnerabilities

Operating system and hardware vulnerabilities sit lower down, and they are harder to fix. Privilege escalation turns ordinary access into administrative access, which usually unlocks everything else. A kernel exploit attacks the core of the operating system. An end-of-life system receives no security updates, and a legacy system is kept running for compatibility and cannot be patched either. Firmware attacks through the Basic Input Output System, or BIOS, and the Unified Extensible Firmware Interface, or UEFI, install malware before the system starts. Side-channel attacks recover secrets from power use or timing, and Spectre and Meltdown leak memory through speculative execution. Low-level flaws survive a reboot, and sometimes a reinstall.

Slide 23 · Mobile, cloud and virtualisation vulnerabilities

Modern platforms add weaknesses of their own. Jailbreaking removes the manufacturer protections along with its limits, and sideloading installs apps from outside the official store, so both make infection far easier. A lost device gives up everything on it unless encryption and remote wipe are in place. In the cloud, misconfigured storage leaves buckets open to the internet, and an interface with weak authentication exposes data. Shared responsibility confusion is the quiet one, because neither side secures what it assumed the other owned. And a virtual machine escape breaks out from a guest to the host, so a hypervisor flaw compromises every guest at once.

Slide 24 · The malware lifecycle and its types

Malware has a lifecycle, and every stage is a chance to break it. Delivery is how it reaches you: an email attachment, a malicious website, or a compromised download. Exploitation is when it abuses a bug, a

misconfiguration or a patch you never applied. Persistence is how it stays, using hidden files and altered settings that survive a reboot. Then the categories. A virus attaches to a file and needs a user to open it, a worm spreads on its own with no user action, and a trojan is disguised as software you installed yourself. Break any one stage and the infection fails.

Slide 25 · Evasion techniques

Malware authors work hard to stay unseen. Polymorphic malware rewrites its own code with every infection, so each copy carries a different signature and signature-based detection fails. Encryption hides the payload until the moment it executes. A rootkit modifies core operating system functions to conceal its files, processes and network connections. Code obfuscation renames variables and strips comments to slow an analyst down. Fileless malware lives in memory rather than on disk, and it abuses a legitimate tool such as PowerShell. Signature detection alone cannot keep up with any of these.

Slide 26 · Ransomware, spyware and rootkits

Ransomware encrypts your files with strong encryption and demands payment in cryptocurrency for the key. Modern crews go further with double extortion: they steal a copy first, then threaten to publish it, which defeats the argument that backups make payment pointless. Spyware gathers information quietly, and a keylogger records every keystroke, either in software or as a small device fitted to the machine. Rootkits hide at a low level with administrative privilege, and a bootkit infects the boot process so the malware reinstalls itself at every startup. Endpoint protection, patching and tested offline backups are the real answers.

Slide 27 · Botnets and command and control

A botnet is a network of compromised machines, each called a zombie, all answering to one operator. The bots are recruited by malware spread through phishing and unpatched software. Command and control servers issue the instructions and collect the results, and attackers work hard to keep that channel alive. Domain generation algorithms produce endless candidate domains, so blocking one achieves nothing. Fast flux rotates the addresses behind a name, and peer to peer botnets remove the central server altogether. Botnets send spam, launch denial of service, and run credential stuffing. Monitor the traffic, alert on it, then isolate the infected host.

Slide 28 · Password and credential attacks

Passwords remain the most attacked control. A brute force attack tries every possible combination, which is slow and depends on length and complexity. A dictionary attack uses a prepared list of common and previously leaked passwords, which is far more efficient. Password spraying takes a few common passwords and tries them across many accounts, deliberately staying under the lockout threshold. Credential stuffing replays username and password pairs stolen in an earlier breach, betting that people reuse them. An offline attack cracks stolen hashes away from the live system, and a rainbow table looks precomputed hashes up rather than cracking them. Lockouts, length, multifactor authentication and hashing with a salt are the answers.

Slide 29 · Injection and application attacks

Injection attacks work because an application trusts input it should have checked. Sequel injection changes the query the database runs, so an attacker can read rows never meant for them. Command injection turns input into an operating system command, and the server runs it. Lightweight Directory Access Protocol, or LDAP, injection manipulates a directory query. Directory traversal uses a crafted path to reach files outside the intended folder. Poor interface design helps the attacker: no authentication, weak validation, or far too much data returned. The defence never changes: validate input, escape output, and use parameterised queries so code and data stay separate.

Slide 30 · Denial of service and amplification

A denial of service attack aims at availability rather than confidentiality. Volumetric attacks flood the bandwidth, and protocol attacks exhaust server resources, such as a Transmission Control Protocol synchronise flood that never completes. Application layer attacks look like real users, such as a Hypertext Transfer Protocol flood, or Slowloris. A distributed denial of service attack uses many machines, often a botnet, which makes blocking sources far harder. Amplification sends a small spoofed request to a Domain Name System, or DNS, server, and the large reply goes to the victim. Rate limiting, blackholing and an upstream protection service are the defences.

Slide 31 · Layer 2 attacks and their defences

Layer Two attacks target the local segment, and they work because the segment trusts itself. A Virtual Local Area Network, or VLAN, hopping attack crosses into a segment the attacker should not reach. Address table flooding fills the switch table with fake hardware addresses until it fails open and broadcasts everything. Address Resolution Protocol poisoning links the attacker's address to another device, which redirects the traffic. A Spanning Tree Protocol attack makes the attacker the root bridge. The answers are all configuration: port security limits the addresses learned per port, Dynamic Host Configuration Protocol snooping blocks unauthorised configuration servers, dynamic ARP inspection validates replies against the binding table, and a Bridge Protocol Data Unit guard disables a port that receives one.

Slide 32 · DNS attacks and their defences

The Domain Name System is a trust system, which is why attackers target it. Cache poisoning injects false records into a resolver, so a user asking for a bank is sent to a fraudulent site. Spoofing answers genuine queries with false responses while leaving the cache untouched. Hijacking goes further and takes over an authoritative server or a registrar account. The impact is always the same: redirection, credential theft and malware delivery. Domain Name System Security Extensions, or DNSSEC, digitally signs every response so tampering is detected. Encrypted DNS protects the queries themselves, and close monitoring catches a change in query patterns early.

Slide 33 · Rogue devices and on-path attacks

Rogue devices are unauthorised equipment inside your perimeter. A rogue access point offers wireless access nobody authorised, copying the real network name, and an evil twin does the same in order to harvest credentials. A rogue Dynamic Host Configuration Protocol server hands out a false gateway and name server, so traffic flows through the attacker. A rogue switch mirrors traffic away to the attacker. With a device on the path, the attacker runs an on-path attack, relaying traffic between two parties who believe they are talking directly. Secure Sockets Layer stripping downgrades a secure connection to plain text. Encryption, certificate validation and wireless scanning are the defences.

Slide 34 · Physical and cryptographic attacks

Some attacks need hands on the equipment, and some attack the mathematics. Device theft is the simplest, because possession gives access to the data and a foothold inside the network. A malicious universal serial bus device, perhaps a drive left in a car park, runs code the moment it is connected. Badge cloning duplicates an access card to walk through a door. A downgrade attack forces a system to negotiate a weaker protocol version. A collision or birthday attack finds two different inputs that produce the same hash. Side channels leak secrets through timing, power or electromagnetic emissions. Locked hardware, port control and salted hashing are the answers.

Slide 35 · Activity: name the attack, then the control

[Run the activity per the instructor notes. 8 minutes pairs, 4 minutes debrief.] A user is redirected to a fraudulent banking site and the resolver cache is clean: DNS spoofing. A switch table fills with invented hardware addresses: address table flooding, answered by port security and dynamic ARP inspection. A server is overwhelmed by a small spoofed request and a huge reply: amplification. A device on the guest network hands out a false gateway: a rogue DHCP server, answered by DHCP snooping. For every answer, name the control that would have stopped it. That pairing is exactly what a scenario question asks for.

Slide 36 · Segmentation

Chapter six is the defensive half, and its purpose is containment. Segmentation divides the network into isolated zones. A virtual local area network separates devices logically, so a group can be segmented by function rather than by desk location, and devices on different VLANs cannot communicate unless a router or firewall allows it. Subnetting does the same job with address space, and microsegmentation isolates individual workloads and applications. Traffic between zones crosses a router or firewall and is inspected there. The prize is containment, because an attacker who lands in one zone cannot move freely through the rest.

Slide 37 · Access control

Access control limits what a compromise can reach. Least privilege says a user or a system gets the minimum access needed to do the job, and nothing more. Need to know is its information cousin: a project

member sees project data and not unrelated company data. Separation of duties splits a critical task between people, so nobody can complete it alone. In one example, one person authorises a payment and another processes it. Review entitlements regularly, because access drifts as roles and responsibilities change.

Slide 38 · Hardening and patch management

Hardening reduces the attack surface of a system by removing what it does not need. If a server only serves web pages, then file transfer and mail services should be switched off, which removes entry points and simplifies monitoring. Change default credentials immediately, because factory passwords are published, and close ports and protocols you do not use. Apply firmware updates and build a secure baseline from a recognised guide, such as the Centre for Internet Security benchmarks. Patch management is a discipline rather than an event: inventory, assess, test, deploy and verify. Every service you switch off is a flaw you no longer have to patch.

Slide 39 · Isolation strategies

Isolation assumes the attacker will get in, and limits how far they get. Sandboxing runs untrusted code in a restricted environment, which is how you safely test an application or analyse a suspicious file. Containerisation packages an application with its dependencies, and each container runs separately from the others and from the host. An air-gapped system is physically separated from every network, including the internet, which makes remote attack very difficult, at the cost of doing updates and data transfers by hand. Containment buys you the time to respond properly.

Slide 40 · Putting it together: the attack chain

Attacks follow a pattern. Recon: the attacker maps the surface and finds a weakness. Vector: a path is chosen, whether email, port, USB or web. Exploit: a vulnerability is triggered to run the payload. Act: access is gained, data is taken, or operations are disrupted. That is the single strike, and the APT lifecycle you met in chapter one is the same chain run slowly, with internal reconnaissance, exfiltration and persistence added at the end. Every defence in this course interrupts one of these steps, which is why knowing the chain matters.

Slide 41 · Exam alignment

Quick alignment with the paper, and it now spans the whole of Domain 2. Objective 2.1: compare threat actors and their motivations, including attributes and false flags. Objective 2.2: explain threat vectors and attack surfaces, including vulnerable software and the supply chain. Objective 2.3: the types of vulnerability, from application and operating system to hardware, cloud and virtualisation. Objective 2.4: indicators of malicious activity, which covers the malware, botnets, injection, denial of service, Layer 2, DNS and credential attacks from chapters four and five. Objective 2.5: the purpose of mitigation techniques, which is chapter six. The questions are scenario-based: you will be handed an attack and asked to label the actor, the vector, the weakness or the control, often two of them at once.

Slide 42 · Quiz

[Direct candidates to Quiz_Session_05.html. 15 minutes.] Open the session quiz. Twenty questions, immediate feedback, and every question is tagged with the exam objective it tests, from 2.1 Threat Actors to 2.5 Mitigation, so you will see the tag above each question. Read every explanation; the distractors teach as much as the answers. Aim for seventy percent or better before moving on.

Slide 43 · Key takeaways, part one

Five takeaways to start. One: risk needs a weakness and somebody willing to exploit it. Two: actors are described by four attributes, resources, sophistication, motivation and intent. Three: nation-state APTs pursue espionage while organised crime pursues profit. Four: the attack surface includes people, and most vectors start there. Five: vulnerabilities live everywhere, in software, firmware, cloud and virtualisation.

Slide 44 · Key takeaways, part two

And five more. Six: malware gets in, hides and persists, then spreads through botnets. Seven: passwords fall to spraying, stuffing and offline cracking, and length, lockouts and multifactor authentication are the answers. Eight: network attacks target trust and availability, through Layer 2, DNS, denial of service and on-path positions. Nine: segment, apply least privilege, harden and patch, then isolate what is left. Ten: defence in depth is the only answer that survives one failure, so assume a breach and contain it.

Slide 45 · Revision checklist

Before next session: retake the quiz until you score seventy percent without guessing. Profile one real threat group and classify it using the four attributes. Map your surface, five physical, five technical and five human vectors. Take ten attacks from this session and pair each with the control that answers it, which is the single most useful revision exercise in this domain. And read ahead to Session 6, on cryptography and public key infrastructure.

Slide 46 · Next session preview

Next time, Cryptography and Public Key Infrastructure. We will cover symmetric and asymmetric encryption, and when to use each; hashing for integrity; digital signatures for authentication and non-repudiation; and the whole PKI world of certificates, certificate authorities, revocation and key management. It is the technical thread that runs behind every control we met today. Thank you for your attention.